Vulnerability Report

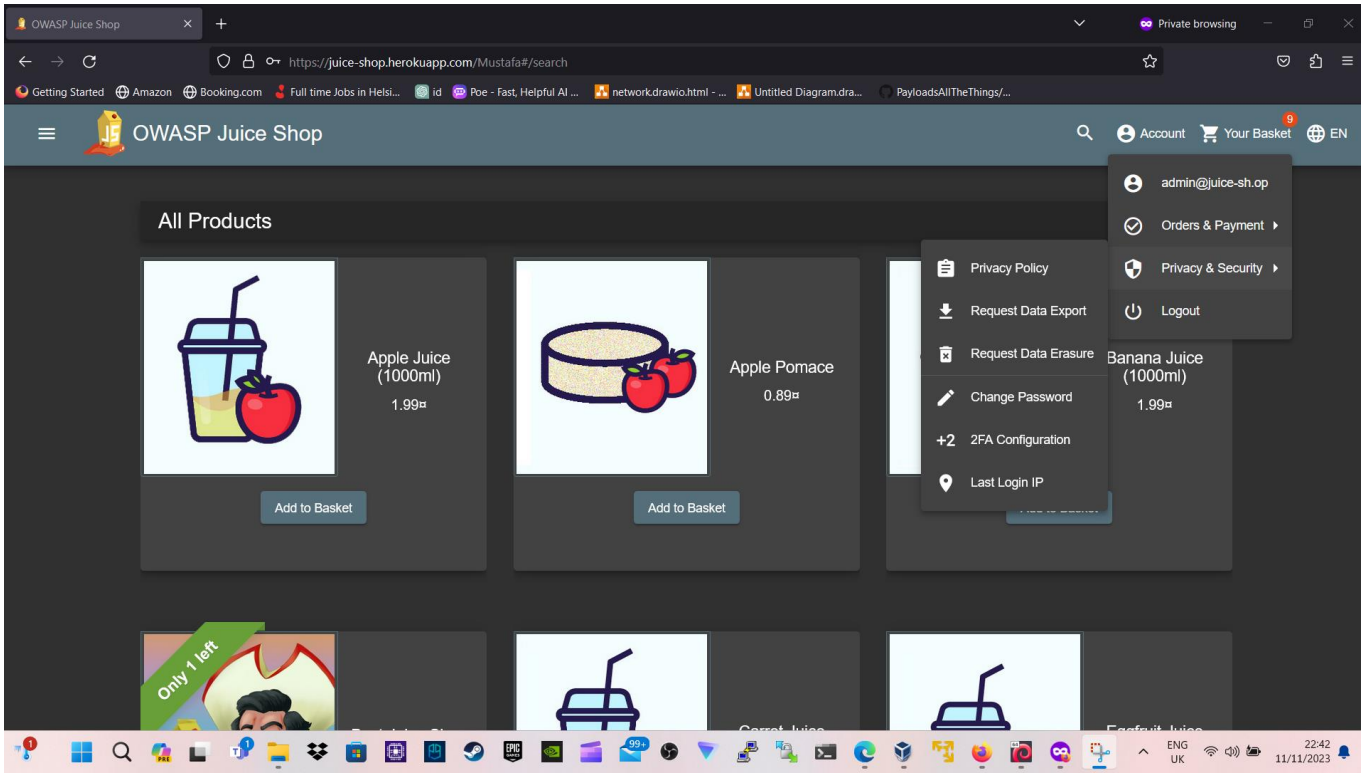
Multiple SQL injection vulns were discovered in the login functionality of the application. These vulns allow an attacker to bypass login screens and gain unauthorized access as an administrator!! compromising the confidentiality and integrity of sensitive information.

1.Scope: The assessment focused on the login functionality of the Juice Shop application.

2.Methodology: SQL injection attacks were performed by injecting malicious SQL queries into the email and password fields during the login process.

3. Vulnerability Details:

- **Screenshots:**



6. Proof of Concept (POC):

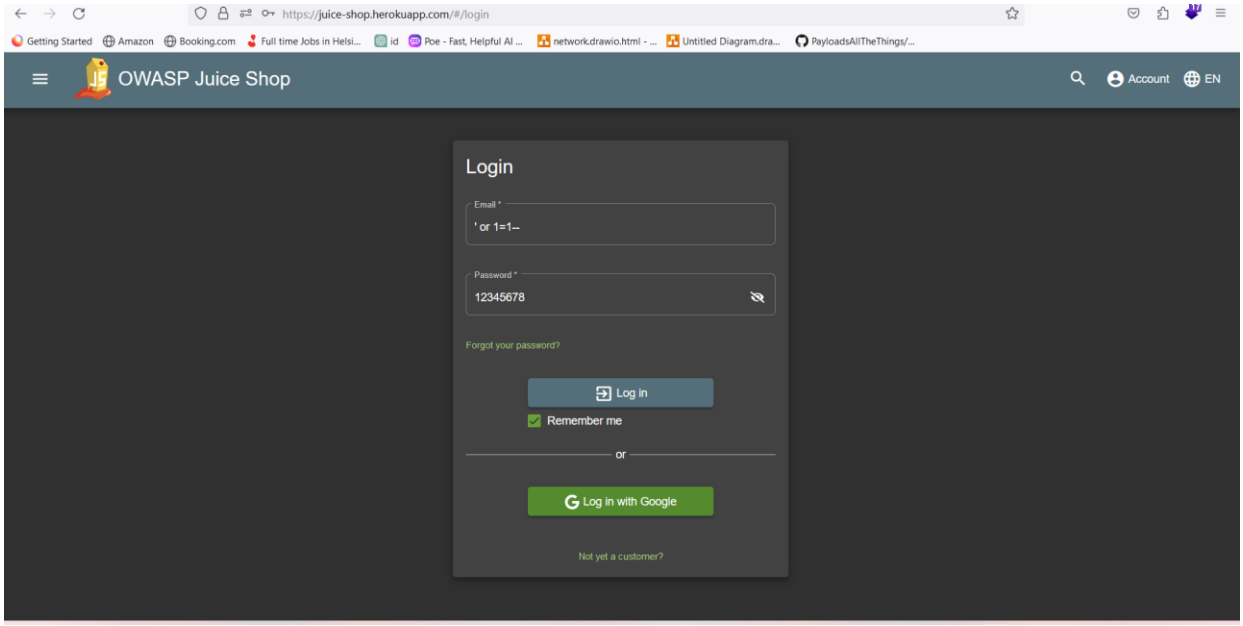
1. open the log in screen 2.

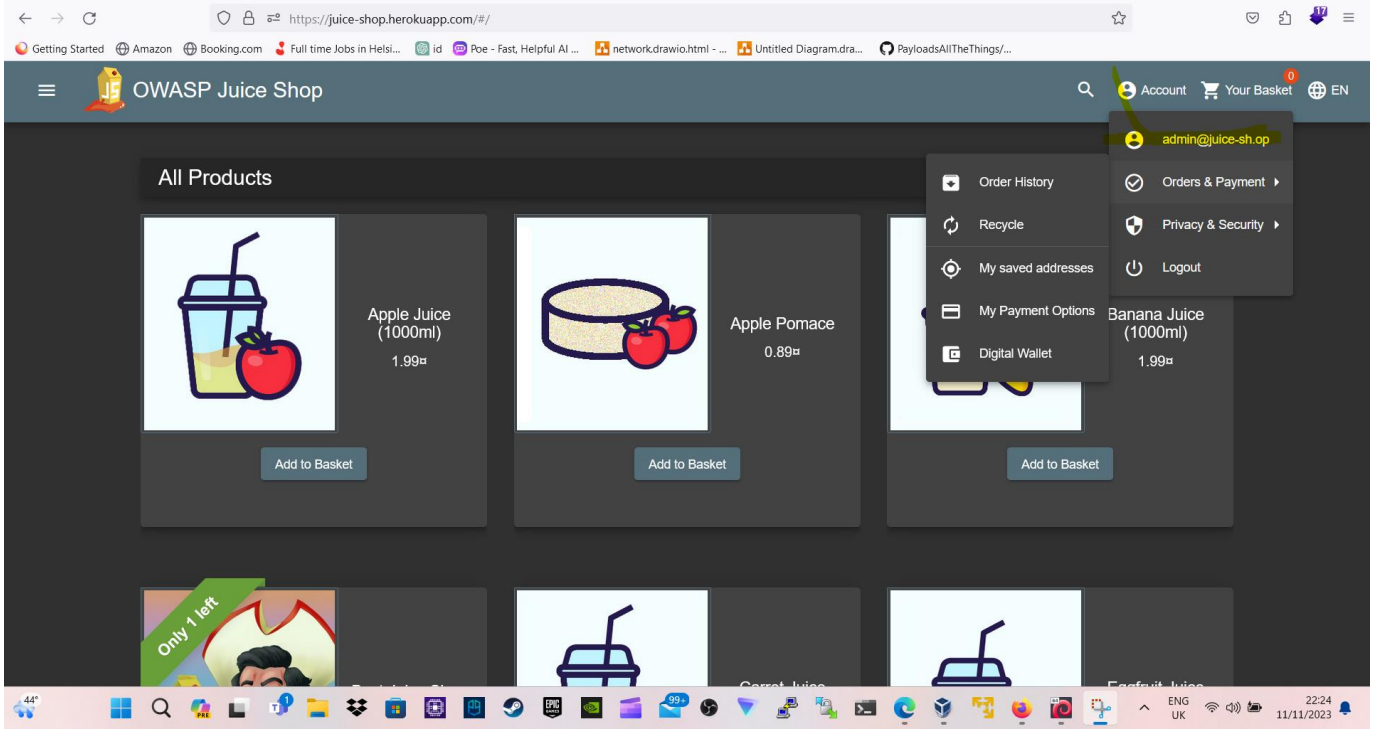
2. in email filed type `' or 1=1--`

3. Type any random pass in password section

4. hit enter

5. you going to logged in as Admin. The following SQL injection payloads were successfully used to bypass login screens and **gain administrative access**: `' or 1=1--`


https://juice-shop.herokuapp.com/#/login
OWASP Juice Shop
Account
EN
Login
Email *
' or 1=1--
Password *
12345678
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?


https://juice-shop.herokuapp.com/#/
OWASP Juice Shop
Account
Your Basket
EN
admin@juice-sh.op
Order History
Orders & Payment
Recycle
Privacy & Security
My saved addresses
Logout
My Payment Options
Digital Wallet
All Products
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Banana Juice (1000ml)
1.99¤
Add to Basket
Only 1 left

https://juice-shop.herokuapp.com/#/privacy-security/data-export

Getting Started | Amazon | Booking.com | Full time Jobs in Helsi... | id | Poe - Fast, Helpful AI ... | network.drawio.html - ... | Untitled Diagram.dra... | PayloadsAllTheThings/...

OWASP Juice Shop

Account | Your Baske

Request Data Export

Export Format : JSON

CAPTCHA :

Enter CAPTCHA *

(Your data export will open

Mozilla Firefox

https://juice-shop.herokuapp.com

{ "username": "", "email": "admin@juice-sh.op", "orders": [{ "orderId": "5267-e0f063e6e8cd6b63", "totalPrice": 8.96, "products": [{ "quantity": 3, "name": "Apple Juice (1000ml)", "price": 1.99, "total": 5.97, "bonus": 0 }, { "quantity": 1, "name": "Orange Juice (1000ml)", "price": 2.99, "total": 2.99, "bonus": 0 }], "bonus": 0, "eta": "5" }, { "orderId": "5267-d59c954d6cf16c3b", "totalPrice": 26.97, "products": [{ "quantity": 3, "name": "Eggfruit Juice (500ml)", "price": 8.99, "total": 26.97, "bonus": 3 }], "bonus": 3, "eta": "0" }], "reviews": [{ "message": "One of my favorites!", "author": "admin@juice-sh.op", "productId": 1, "likesCount": 0, "likedBy": [] }, { "message": "I bought it, would buy again. 5/7", "author": "admin@juice-sh.op", "productId": 3, "likesCount": 0, "likedBy": [] }], "memories": [] }

ENG UK

https://juice-shop.herokuapp.com/profile

Getting Started | Amazon | Booking.com | Full time Jobs in Helsi... | id | Poe - Fast, Helpful AI ... | network.drawio.html - ... | Untitled Diagram.dra... | PayloadsAllTheThings/...

User Profile

Email:
admin@juice-sh.op

Username:
Mustafa

Set Username

\Mustafa

File Upload:
Browse... No file selected.

Upload Picture

or

Image URL:
e.g. https://www.gravatar.com/avatar/526703ac2bd7cd675e872

Link Image

https://juice-shop.herokuapp.com/Mustafa#/login

Getting Started | Amazon | Booking.com | Full time Jobs in Helsi... | id | Poe - Fast, Helpful AI ... | network.drawio.html - ... | Untitled Diagram.dra... | PayloadsAllTheThings/...

OWASP Juice Shop | Account | EN

Login

Invalid email or password.

Email *
admin@juice-sh.op

Password *
••••••••••

Forgot your password?

Log in

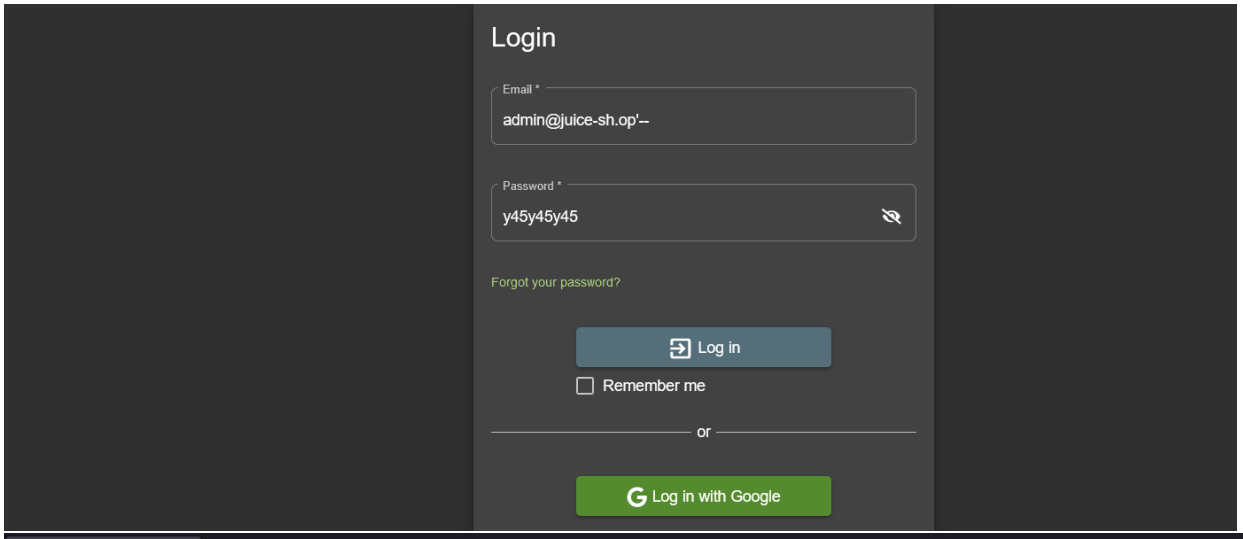
Remember me

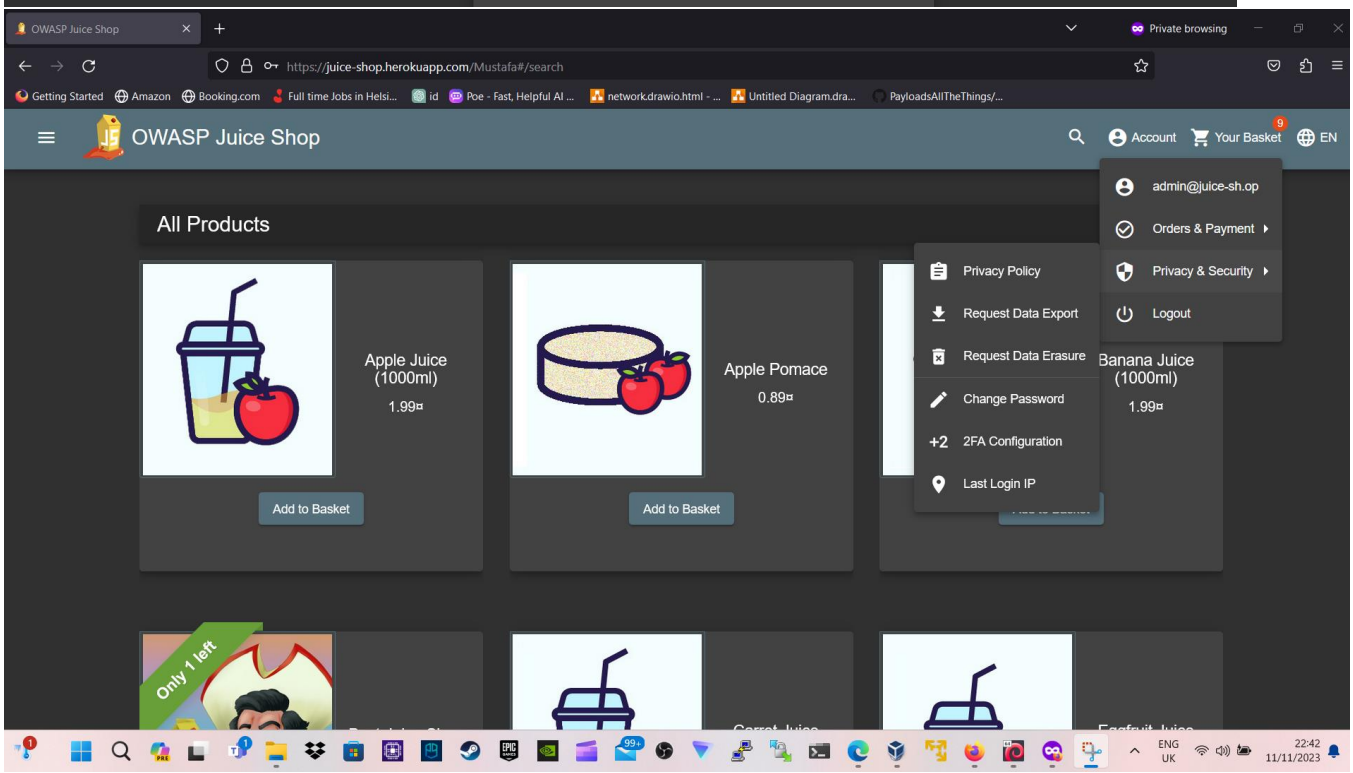
or

Log in with Google

Not yet a customer?

ps://www.jobly.fi/en/jobs/helsinki/full-time?gclid=Cj0KCQjwqs6IBhCxARIsAG8YcDjpSsOkIpTAwA8YNSODSTbfO96qLVfIC8NmEOBRTupzMU2zjB4i5dIaAhXJEALw_wcB





4. Risk Assessment:

- **Impact: High**
- **Likelihood of Exploitation: High**
- **Potential Consequences: Unauthorized access, data manipulation, and exposure of sensitive information.**

5. Recommendations:

- Immediate patching of the SQL injection vulnerabilities.
- Implementation of input validation and parameterized queries.
- Regular security assessments and penetration testing to identify and address potential vulnerabilities.